DELIVERABLES PACKAGE

Q3 GRC Phishing Simulation

Dashboard, Risk Assessment, and Executive Summary

Field	Detail
Name	Adebukola Olanipekun
Registration Details	C11/26/CGRCE/17603 ,Cohort 11 CGRCE
Date	31st October, 2026

Deliverable 1: GoPhish Campaign Results Dashboard

Campaign details

Field	Value	Field	Value
Campaign	Q3 GRC Phishing Simulation	**Status**	Completed
Template	VPN Password Reset Required	**Launched**	2026-10-31 09:00
Landing page	Fake VPN Portal	**Completed**	2026-10-31 17:00
Sending profile	Mailtrap Test	**Group**	Lab Test Group (20)

Sent	Opened	Clicked	Submitted	Reported	Errors
20 (100%)	**18** (90%)	**15** (75%)	**10** (50%)	**2** (10%)	**0** (0%)

Metric tiles

EMAILS SENT **20** 100%	OPENED **18** 90%	LINK CLICKED **15** 75%
DATA SUBMITTED **10** 50%	REPORTED **2** 10%	EMAIL ERROR **0** 0%

Timeline / event log

Time	Event
09:00	Campaign launched: 20 emails queued
09:02	20 emails sent successfully (0 errors)
09:14	First email opened (Lab User)
09:21	First link clicked (Lab User)
09:23	First credential submission (Lab User)
10:05	10th credential submission recorded
11:30	First "Reported" event (Lab User 07)
14:12	Second "Reported" event (Lab User 14)
17:00	Campaign auto-completed

Per-user status (anonymized for reporting)

User	Opened	Clicked	Submitted	Reported
User 01	✓	✓	✓	—
User 02	✓	✓	✓	—
User 03	✓	✓	✓	—
User 04	✓	✓	✓	—
User 05	✓	✓	✓	—
User 06	✓	✓	✓	—
User 07	✓	✓	✓	✓
User 08	✓	✓	✓	—
User 09	✓	✓	✓	—
User 10	✓	✓	✓	—
User 11	✓	✓	—	—
User 12	✓	✓	—	—
User 13	✓	✓	—	—
User 14	✓	✓	—	✓
User 15	✓	✓	—	—
User 16	✓	—	—	—
User 17	✓	—	—	—
User 18	✓	—	—	—
User 19	—	—	—	—
User 20	—	—	—	—

Users 19 and 20 had no interaction. Users 07 and 14 reported the email; both had also clicked.

Completed Phishing Risk Assessment Table

Group size	Campaign	Date	Dataset
n = 20	Q3 GRC Phishing Simulation	2026-09-15	Worked example

Metric	Result	Rate	Risk interpretation	Control failure / implication
Emails sent	20/20	100%	Delivery baseline confirmed; sending profile functional.	No failure; baseline metric.
Emails opened	18/20	90%	High susceptibility to engaging with suspicious emails.	Security awareness training is ineffective at the "recognize" stage.
Links clicked	15/20	75%	High risk of users executing malicious actions.	Users are not verifying links (no hover / URL inspection). Filtering effectiveness cannot be judged from a sandbox test (see limitations).
Credentials submitted	10/20	**50%**	**CRITICAL RISK.** High probability of credential compromise.	**MFA is an absolute requirement** to mitigate stolen credentials.
Reported to IT	2/20	10%	Very low reporting culture.	No easy reporting mechanism, or users fear blame. Recommend a "Report Phish" button and a no-blame policy.
Email errors	0/20	0%	No delivery failures.	No failure.

Aggregate risk rating: CRITICAL

Justification

1. Credential submission (50%). Half of the group handed credentials to a fake site. With MFA not yet universal, each of those would be a real account compromise.

2. Click rate (75%). More than double the roughly one-third global baseline reported by KnowBe4 for users before training, so recognition controls are failing broadly.

3. Report rate (10%). Users who suspect phishing are mostly not reporting it, so the detection-and-reporting path is weak.

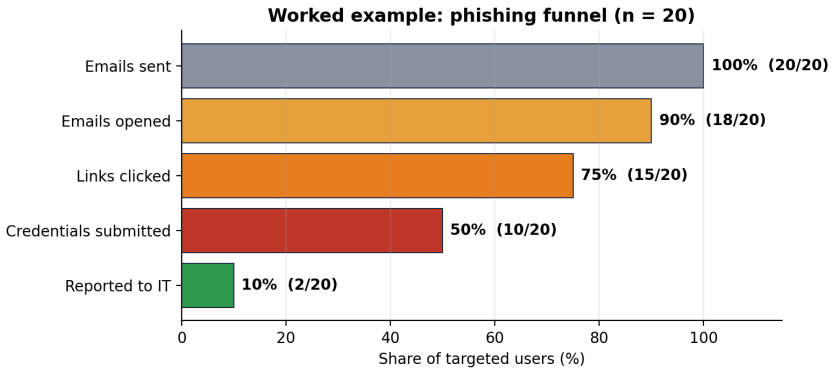


Figure 1. Phishing funnel, share of all targeted users (n = 20)

Supplementary analysis

Funnel stage conversion

Stage	Users	Of all sent	Of previous stage
Sent	20	100%	n/a
Opened	18	90%	90.0%
Clicked	15	75%	83.3% of openers
Submitted credentials	**10**	**50%**	**66.7% of clickers**
Reported (from clickers)	2	10%	13.3% of clickers

Analysis	Finding	Implication
Funnel conversion	83% of openers clicked, and two-thirds of clickers submitted credentials.	Few users drop out at any stage, so the failure is broad rather than concentrated at one point.
Breadth of failure	10 of 20 users (50%) submitted credentials.	A large share of the group, not a small cohort, which suggests a systemic training gap. One campaign cannot identify repeat clickers; track per-user results across campaigns for that.
Reporting vs. clicking	Only 2 of 15 clickers reported (13.3%).	The path from suspicion to report is broken; reporting must be made frictionless.
Benchmark comparison	75% click rate vs. about 33% global baseline for untrained users (KnowBe4 2026 Phishing by Industry Benchmarking Report, 33.1%).	Well above the baseline. That report measures clicking, not credential submission, so there is no equivalent published threshold for the 50% submission rate. The same report found roughly 4% after 12 months of training, a reference point for the post-training target.

Risk register entry (suggested)

Field	Value
Risk ID	HUM-001
Risk	Employees submit credentials to phishing sites
Likelihood	High (50% submitted credentials in the simulation)
Impact	High (account takeover, lateral movement, data breach)
Inherent risk	Critical
Key control	MFA (not yet universal)
Residual risk	High until MFA and the training loop are complete
KRI	Credential submission rate (illustrative target: below 10%)

-

Executive Summary and Recommendations

MEMORANDUM	
To	CISO, Head of HR, Executive Management
From	GRC Audit Team
Date	2026-10-31
Subject	Results of Q3 Controlled Phishing Simulation and Human Risk Assessment
Classification	Internal: aggregate results only

1. Executive summary

A controlled, authorized phishing simulation was conducted against a test group (n = 20) to assess organizational resilience to social engineering attacks. Results indicate a **critical level of human risk**: **50% of targeted users submitted credentials** to a simulated malicious site. This represents a severe threat to our information assets and demonstrates that current security awareness controls are not achieving their intended effect.

2. Key findings and metrics

Metric	Result	Rate
Email open rate	18/20	90%
Link click-through rate	15/20	75%
Credential submission rate	**10/20**	**50%: most critical finding**
Reported to IT	2/20	10%
Delivery errors	0/20	0%

Interpretation: Half of the test group would have compromised corporate credentials in a real attack. The high open (90%) and click (75%) rates show broad recognition failure, and the low report rate (10%) shows that the detection-to-report path is not working.

3. Risk analysis

This data reveals that our current security awareness program is not achieving its desired effect. A successful real phishing attack could lead to:

- **Initial network access** for attackers (a foothold for lateral movement).
- **Data breaches and financial loss** (credential compromise leading to account takeover).
- **Reputational damage and regulatory fines** (under GDPR, CCPA, and others).
- **Business email compromise** and downstream fraud.

Control	Failure observed
Awareness training	Fails at the recognition and reporting stages
Email filtering	Not evaluated by this sandbox test; verify with a campaign through production mail flow
Authentication	Credential compromise would succeed absent universal MFA

4. Recommended actions (prioritized)

Priority	Action	Detail
1	Accelerate MFA rollout	**Immediate technical control.** Deploy across all critical systems. This is the single most effective control against stolen credentials and should be the top priority.
2	Revamp the training program	Move from annual compliance videos to **continuous, engaging, role-based training** (micro-learning, real examples, simulated phishing), with targeted remediation for repeat clickers.
3	Integrate into processes	Embed **phishing simulations** into onboarding for all new hires and run them **quarterly** for all staff. Close the loop by re-testing after training and reporting the improvement delta.
4	Update policy and reporting	Review the **Acceptable Use Policy (AUP)** to define requirements for identifying and reporting phishing, and establish a **one-click "Report Phish"** mechanism with a no-blame reporting culture.
5	Metrics and governance	Track click and report rates as **Key Risk Indicators (KRIs)** on the risk register; report quarterly to the CISO and annually to the board.

5. Requested decisions

- **Approve** accelerated MFA funding and timeline.
- **Approve** the training program redesign budget.
- **Endorse** the no-blame reporting policy and "Report Phish" tooling.

6. Data handling statement

> All captured test credentials were purged per the Rules of Engagement. Results are reported in aggregate; no individual is identified. Findings are for control improvement, **not disciplinary action**.